

Project Security & Features Report

Shree Ramchandra Temple (Ram Mandir) — Website and Administration Portal

The security provided, the cPanel server it runs on, and what the system does

Prepared by	ZeroInfinity Infotech — Administration
Prepared for	Ram Mandir (Shree Ramchandra Temple) administration
Verified by	Sujan Subedi, Founder, ZeroInfinity Infotech
Report date	6 October 2026
Version	2.0 (replaces version 1.0 of 5 October 2026)
Classification	Confidential — for the temple administration only

Contents

1. What security does the software provide?
2. The system and its server
3. What the software does (features)
4. Security built into the software
5. Server security on cPanel
6. Backup and recovery
7. Go-live checklist
8. If something goes wrong
9. Routine maintenance
10. Shared responsibilities
11. Scope and limits of this report
12. Words used in this report
13. Verification and sign-off

1. What security does the software provide?

The temple administration asked which security ZeroInfinity Infotech provides in the Ram Mandir software. This section answers in short. The rest of the report gives the detail: how the system is arranged on the cPanel server (section 2), what it does (section 3), the protection built into the software (section 4) and into the server (section 5), backups (section 6) and the steps for going live (section 7).

In short

The protection works in two layers. The software itself checks every request: who is asking, what they are allowed to do, and whether what they sent is safe. The cPanel server around it adds the outer layer: encrypted connections, a firewall, attack filtering, malware scanning and hidden private files. A full security audit of the software was carried out on 5 October 2026. Weak points were found by reviewing the code and by attacking a throw-away copy of the system (never the live data), they were fixed, and the same attacks were run again to prove each fix. The main protections in the software are in place. The server protections in section 5 are switched on and checked when the system goes live.

Security in ten points

- **1. Safe sign-in.** Strong password rules, passwords stored in a form that cannot be read back, sign-in with Google or an e-mailed one-time code, and automatic blocking of guessing.
- **2. Controlled access.** Visitors, administrators and a super administrator. Each administrator only gets the areas they need, and this is enforced on the server.
- **3. Safe input.** Everything typed into a form, every link and every upload is checked, so that nobody can plant a script or a database command.
- **4. Safe donations.** Each payment is confirmed directly with eSewa, Khalti or ConnectIPS by the server. Nothing is trusted just because a browser says so.
- **5. Safe e-mail.** Nobody receives the newsletter without confirming their own address; every message can be unsubscribed from; daily limits protect the mail account.
- **6. Protection against abuse.** Limits on repeated requests, a filter for spam and rude messages, and approval of visitor reviews before they appear.
- **7. Visitor privacy.** Phone numbers, booking references and secret links are kept out of logs and statistics.
- **8. An audit trail.** Administrator actions are recorded with who and when.
- **9. A protected server.** On cPanel: HTTPS, firewall, web application firewall, malware scanning, hardened logins, and settings and keys kept outside the public folder.
- **10. Tested and recoverable.** More than 290 automated security and feature checks, independent reviews, a built-in backup and restore tool, and a backup plan for the server.

Security at a glance

Area	What it means for the temple	Status
Sign-in	Passwords are stored in a scrambled form that cannot be read back. People can also sign in with Google or an e-mailed one-time code. Guessing is slowed down and blocked.	In place
Who can do what	Visitors, administrators and one super administrator. Each administrator only gets the areas the super administrator allows, and this is checked on the server, not just hidden on the screen.	In place

Area	What it means for the temple	Status
Data entered into the site	Everything typed into forms is cleaned before it is used. Unsafe links are refused. Visitors can upload pictures only.	In place
Donations and bookings	Every payment is confirmed directly with eSewa, Khalti or ConnectIPS by the server.	In place
E-mail and newsletter	Confirmation before anyone is added, an unsubscribe link in every message, and daily sending limits.	In place
Visitor privacy	Phone numbers, booking references and secret links stay out of logs and analytics.	In place
Audit trail	Administrator actions are recorded (who, what, when) and can be reviewed by the super administrator.	In place
Server protection on cPanel	HTTPS, firewall, web application firewall, malware scanning, hardened logins and hidden private files (section 5). Switched on and checked at go-live.	Recommended
Backup and recovery	A backup and restore tool is built into the portal. Nightly off-server backups of the hosting account are still to be set up (section 6).	Recommended
Live keys and settings	Strong, separate secret keys and the live settings for the live server (sections 2.2 and 7).	Recommended

How to read the status labels in this report

- **In place** — built into the version of the software prepared by ZeroInfinity Infotech, or provided by the cPanel platform itself, and checked in the code and by automated tests. It protects the live website once that version is deployed (section 7).
- **Recommended** — to be switched on, configured or checked at go-live, by ZeroInfinity Infotech or by the temple administration (server settings, accounts, hosting). The software cannot do these by itself.

2. The system and its server

The Ram Mandir system has two parts that work together, plus a few outside services. The website is what visitors and administrators see. The temple API is the application behind it that holds every rule: sign-in, access, payments, e-mail and the audit log. Figure 1 shows how they are arranged on the cPanel hosting server.

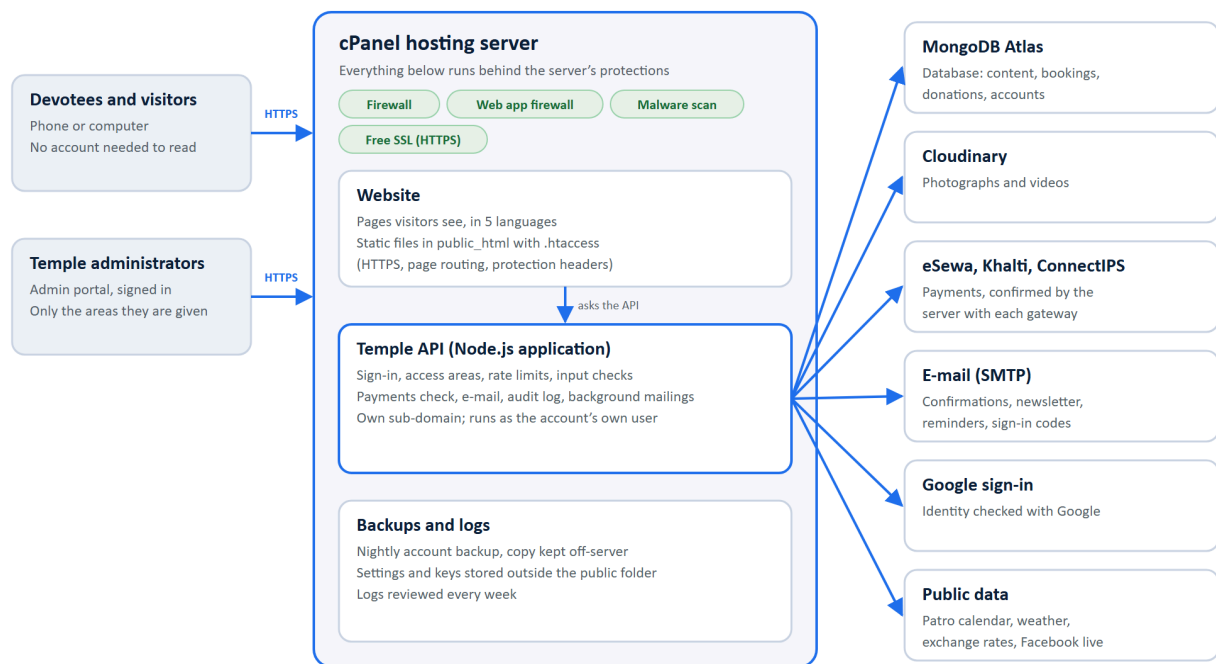


Figure 1 — How the Ram Mandir system is arranged on the cPanel server

Part	What it is	Where it lives
Website	The pages visitors and administrators see (React), in five languages.	Static files in the public_html folder of the cPanel account, with a supplied .htaccess file.
Temple API	A Node.js (Express) application with all the rules: sign-in, access control, payments, e-mail, audit log and the background newsletter sender.	A Node.js application created in cPanel, on its own sub-domain.
Database	MongoDB Atlas, a managed cloud database. It holds the content, bookings, donation records and accounts.	Atlas, outside the cPanel server.
Photographs and videos	Cloudinary, a media service.	Cloudinary.
E-mail	A mail account used through SMTP for confirmations, the newsletter, reminders and sign-in codes.	The mail provider.
Payments	eSewa, Khalti and ConnectIPS. The server verifies each payment with the gateway.	The payment gateways.
Public data	Google sign-in, the Nepali patro calendar, weather, exchange rates and the temple's Facebook live video.	Outside services, each used only for its own job.

2.1 How it is deployed on cPanel

- **Website.** The website is built into a folder of static files and uploaded to the domain's public_html folder together with the supplied .htaccess file. That file redirects to HTTPS, lets every page address open correctly, hides private files and adds the browser protection headers.
- **API.** The API is created in cPanel under "Setup Node.js App". Its application folder is outside public_html, so a browser can never download it. The start-up file is server.js. We recommend giving it its own sub-

domain, with its own free SSL certificate.

- **Settings and keys.** They are typed into the environment-variable screen of that cPanel application, never into a file inside the public folder or the code repository.
- **Database.** MongoDB Atlas, with its access list limited to the hosting server's address.
- **Protection around it.** Free SSL certificates (AutoSSL), the server firewall, a web application firewall, malware scanning and account backups, all provided by cPanel and WHM (section 5).

2.2 Settings the server needs

Setting	What it is for
NODE_ENV = production	Switches on the production protections and the safe, generic error messages.
FRONTEND_URL	The website's https address: used in e-mail links, payment return pages and as the allowed origin.
BACKEND_URL	The https address of the API: used in the confirm and unsubscribe links of e-mails. Mailings are refused in production while it is missing.
CORS_ORIGINS	Any further website address allowed to use the API (optional).
TRUST_PROXY	How many servers sit in front of the API: 1 on cPanel, 2 if Cloudflare is added. It lets the limits see the real visitor address.
MONGODB_URI	The database connection, with its own database name and user.
JWT_SECRET	The key that signs logins. A long random value, different from any test copy.
EMAIL_USER, EMAIL_PASS	The mail account (an app password) used for confirmations, the newsletter and reminders.
Payment keys	eSewa, Khalti and ConnectIPS keys, in live mode, with the temple's real return addresses.
Cloudinary and Google keys	For photographs and videos, and for Google sign-in.

The server prints a clear warning at start-up for any unsafe value (a weak signing key, a placeholder address, a gateway still in test mode, a missing API address), and the website build refuses to run while placeholder addresses remain. The software is developed and tested on Node.js 24 (the project asks for 24 or newer). Please use the newest version the cPanel Node.js selector offers, and tell ZeroInfinity Infotech if it is older, so that compatibility is confirmed before go-live.

3. What the software does (features)

3.1 The public website

Feature	What it does
Home page	Temple timings, daily aarti, daily quote, upcoming events, a notice pop-up, and Live Darshan (the live video from the temple's Facebook page, or a saved video link).
About, History and Team	The story of the temple, its history, and the committee and staff.

Feature	What it does
Events	Upcoming and past events with photographs. Visitors can mark interest, share an event and send a puja booking request.
Puja booking	Book ceremonies and services, receive a booking reference, and see the booking again under “My bookings”.
Donations	Donate through eSewa, Khalti or ConnectIPS, or by bank account or QR code. A receipt after each donation, and a list of the person’s own bookings and donations on their Profile page.
Gallery	Photographs in categories, each with a title and description. Temple videos are shown on the home page.
Blogs	Articles and notices published by the temple.
Calendar (Patro)	Nepali calendar with festivals, tithi, Ekadashi, Purnima, Aunsi and sunrise and sunset. Dates can be added to a phone calendar, and a signed-in visitor can ask for an e-mail reminder before a festival.
Tools	Date Converter (Nepali and English dates), Unicode / Preeti Converter, Currency Exchange, and Time & Weather for Kathmandu.
Contact	A message form with a spam and rude-language filter, map and directions, frequently asked questions, and visitor reviews that appear only after an administrator approves them.
Stay updated (newsletter)	Visitors subscribe with their e-mail address and choose Events, Festival wishes and News. They confirm by e-mail first and can unsubscribe at any time.
Chat assistant	Answers common questions about timings, events, donations and bookings.
Language, phone and search	Five languages (English, Nepali, Hindi, Chinese, Tamil), phone-friendly pages, Privacy and Terms pages, and page titles, descriptions and a sitemap that help search engines.

3.2 Visitor accounts

- Sign in with Google, with an e-mailed one-time code, or with an e-mail address and password.
- A profile page, saved login on the same device, and password reset by e-mail code.
- An account is needed for donations and for the personal lists on the Profile page and “My bookings”. Browsing the website and sending a contact message do not need one.

3.3 The administration portal

Section	What administrators can do
Overview	A summary of recent activity.
Content	Home settings, About, History, Team, Events, Daily Aarti and Info, Blogs, Gallery, and the Notice pop-up.

Section	What administrators can do
Management	Puja bookings and the price list, donations (review and approve), contact messages, subscribers and mailings, visitor reviews, visitor analytics, backup and restore, and cloud storage.
Accounts	Users, administrators and their access areas (super administrator), the audit log, and “My account”.
Settings	Hero banner, daily quote, temple timings, logo, footer, social links and the Facebook live video.

3.4 What only the super administrator can do

- Create, suspend and remove administrators, and choose which areas each administrator may use.
- Change the donation switches and the donation account details.
- Restore or delete backups, switch the maintenance page on or off, and use the database tools (which only show this website’s own data and never show passwords).

3.5 Extra capabilities

Capability	What it gives the temple
Newsletter and festival greetings	Event announcements and new blog posts are e-mailed to subscribers who chose them, and a greeting is sent on the day of about nine major festivals. The administrator can switch each festival on or off, write the wording, send a test to themselves first, and see every mailing’s progress.
Festival reminders	A signed-in visitor can ask for an e-mail reminder before a festival, with a link to stop it.
Access areas	Each administrator is limited to the areas they need: content, bookings, donations, contact messages, users, analytics, system.
Audit log	A record of who did what and when in the portal.
Visitor analytics and notifications	Visitor numbers and places, and alerts for new bookings, donations and subscribers.
Backup and cloud storage tools	Create and download backups, and manage the photographs and videos stored in the cloud.
Maintenance page	The super administrator can show visitors a maintenance page while work is done.
Message and review moderation	A filter blocks spam, links and rude messages; reviews wait for approval.
Add to phone calendar	Festivals and temple dates can be saved to a phone or computer calendar.

4. Security built into the software

4.1 Safe sign-in and passwords

- **Passwords are never kept as typed.** They are stored in a scrambled form (bcrypt) that cannot be turned back into the password.
- **One password rule everywhere.** At least 8 characters, no common passwords such as “123456”, no simple repeats or runs, and the password may not contain the person’s e-mail name.
- **Google sign-in is checked with Google itself.** The e-mail one-time code is 6 digits, valid for 10 minutes, usable once, with a limit on wrong guesses.
- **No hints for attackers.** A wrong password and an unknown e-mail address give the same answer at the same speed. Failed attempts are counted per account and per address, and repeated failures pause sign-in.
- **Password reset is hardened.** A 6-digit code, five guesses per code, a limited number of codes per hour, and “forgot password” answers the same whether or not the e-mail has an account.
- **Sessions can be ended.** A login lasts 30 days and renews while the person keeps visiting (the temple asked for saved logins). An administrator can suspend an account, and changing a password signs the person out on their other devices.
- **The super administrator account is created once.** The password in the settings file is never applied again, so a password changed inside the portal cannot be silently undone.

4.2 Who can do what

- **Three levels:** visitor, administrator, super administrator.
- **Access areas.** Administrators are given only the areas they need. Every request is checked on the server. This was tested by calling all 256 server routes as an anonymous visitor and as an ordinary user: nobody could change anything.
- **New administrators start with no powers.** An administrator on a temporary password cannot use any staff function until they choose their own password.
- **Sensitive actions are for the super administrator only:** donation switches, donation account, restoring or deleting backups.

4.3 Protection of what people type and click

- **Hidden database commands are stripped.** Text such as database operators typed into a form is removed before it reaches the database, and every search built from typed text is made safe.
- **Pages show text safely.** The website never inserts typed text as raw HTML. Links saved by administrators (map, footer buttons, social links, live video, payment screenshot) are refused if they could run a script. This was proved with deliberately poisoned data in a real browser.
- **E-mails are safe.** Everything a visitor typed is made harmless before it is placed into an e-mail, and each message goes to exactly one recipient.
- **Size limits.** Requests and uploads have size limits so that very large requests cannot slow the site down.

4.4 Files and uploads

- Visitors can upload pictures only: a profile photo up to 5 MB and a payment screenshot up to 10 MB, with an hourly limit. No video, SVG or web-page files are accepted from visitors.
- Administrators can upload photographs and videos up to 50 MB.

- Files are stored with Cloudinary, not on the web server's disk.

4.5 Donations and payments

- The server confirms every payment with eSewa, Khalti or ConnectIPS itself (signature, amount, owner and pending state). Nothing is trusted from the browser.
- Amounts must be real numbers within a sensible range. A payment is counted once even if it is confirmed twice at the same moment.
- The test-payment hints used during development are hidden on the live website, and error messages never reveal payment settings.

4.6 E-mail and the newsletter

- **Confirmation first (double opt-in).** Subscribing only sends a confirmation e-mail. The person is added after pressing the confirm button. The link is valid for 7 days, and addresses that never confirm are removed after 30 days.
- **Easy to leave.** Every message carries the person's own unsubscribe link, and the mail program's one-click unsubscribe works too.
- **No account guessing.** The subscribe form gives the same answer, at the same speed, for a known and an unknown address, and a hidden trap field catches simple robots.
- **Limits that protect the mail account.** A limit per address and per hour, a daily ceiling on confirmation e-mails, and a daily ceiling on newsletter e-mails (300 by default, below the mail provider's own limit). A large mailing simply carries on the next day.
- **Sensible behaviour.** Nobody is mailed twice; someone who unsubscribes during a mailing is not mailed afterwards; a mailing can be stopped at once; sending stops by itself if the mail server keeps refusing; a festival greeting is sent only on its own day; and in production nothing is sent while the API address is not set, because the unsubscribe links would not work.
- **Calendar reminders** go only to the e-mail address of the signed-in account, each with a link to stop the reminder.

4.7 Protection against abuse and overload

- An overall ceiling per visitor address, and stricter limits on sign-in, sign-up, password reset, contact messages, reviews, bookings, uploads, subscribing and reminders. The server learns the visitor's real address behind the hosting server, and counts an IPv6 visitor by their whole address block, so one person cannot use up everybody's allowance or dodge the limit.
- The contact form filters rude words (in several languages), links, spam and keyboard-mash text. Visitor reviews wait for an administrator to approve them.
- One failed background task can no longer stop the whole website.

4.8 Visitor privacy

- Logs record the page, not the full address (which could contain a phone number or a booking reference). Sign-in logs contain no e-mail addresses.
- The secret part of a password-reset link is never stored in the visitor statistics, and visitor addresses are no longer sent to an outside lookup site in plain text.
- Visitors see generic error messages; technical detail stays on the server. The super administrator's database screens never show password hashes or reset codes.

4.9 Audit trail and warnings

- Administrator actions (for example changing content, approving a donation, sending a mailing, changing a setting) are recorded with who and when, and can be reviewed in the Audit log.
- New bookings, donations and subscribers create notifications for the administrators.
- When the server starts it prints a clear warning if a live setting is unsafe, and the website build refuses to run while placeholder addresses remain.

4.10 Secrets and configuration

- No passwords or keys are written in the program code. They are kept in the settings of the hosting application and in a private settings file that is excluded from the code repository; an example file without secrets is provided.
- Software libraries with known weaknesses were updated during the audit, and the tests are repeated after every change.

4.11 Browser protection headers

Where	What is set	Status
The API	No content-type guessing, no framing, HTTPS-only pinning, no referrer, a strict content policy, and no software name or version in responses.	In place
The website on cPanel	A ready-made .htaccess file (included in the website package) sends the protection headers and a tested content-security policy in “report-only” mode, which cannot break the site. After a week without reports it is switched to enforcing.	Recommended

4.12 Testing and independent review

- **The audit of 5 October 2026.** Three independent reviews (server code, website code, secrets and deployment files) produced 51 distinct findings. 32 were fixed completely in the code, 8 need action by the temple (keys, accounts, hosting) and also received a code safeguard, and 11 are low-risk and were partly fixed or accepted.
- **A second independent review of the fixes themselves** found 13 problems in the first version of the fixes. 12 were fixed and re-tested and 1 was accepted.
- **Attack simulations on a throw-away copy** (never the live data): forged logins, injection, access to other people’s data, cross-site calls, oversized requests, upload tricks and rate limits. 132 automated checks pass (112 on the server, 9 on uploads and 11 in a real browser).
- **The newsletter was reviewed separately.** Independent reviews of its server code and of its website screens raised 13 and 8 points; all were addressed and re-tested. It has 161 automated checks of its own (server, background sending and a real browser). The e-mail sign-in code and the access-area system have their own test suites.

5. Server security on cPanel

These protections sit around the application, on the hosting server. We recommend applying all of them at go-live and reviewing them every quarter. Items marked Recommended are configuration steps for the server

(cPanel and WHM) and the accounts around it; ZeroInfinity Infotech can carry them out as part of deployment. Where the temple's hosting provider manages WHM, the provider applies the WHM-level items.

5.1 Accounts and access

Control	What to do and why	Status
Two-factor authentication	Turn on 2FA for every cPanel and WHM login. A stolen password alone is then useless.	Recommended
Strong, unique passwords	At least 16 characters, kept in a password manager. Enforce cPanel's password-strength setting.	Recommended
Limit access by address	Allow WHM and cPanel only from known office addresses where possible.	Recommended
SSH hardening	Key-based login only, no direct root login and no password login.	Recommended
A cPanel account of its own	Keep the temple site in its own hosting account, separate from other websites, so a problem elsewhere cannot reach it.	Recommended
Least privilege	Separate logins for each person; remove the access of former staff on the same day.	Recommended
Limited user	The application runs under the hosting account's own limited user, never as root.	In place

5.2 Firewall and attack blocking

Control	What to do and why	Status
Server firewall (CSF or similar)	Open only the ports needed (80, 443, and SSH from allowed addresses). Close everything else.	Recommended
Brute-force protection	Enable cPHulk and/or fail2ban to block repeated failed logins automatically.	Recommended
Web application firewall	Enable ModSecurity with the OWASP Core Rule Set to filter common web attacks.	Recommended
Traffic filtering	Optionally put the site behind a CDN and filtering service such as Cloudflare's free plan to absorb floods of traffic. Set TRUST_PROXY to 2 if this is done.	Recommended
API reached only through the web server	Visitors reach the API only through the web server; the application is not exposed on a port of its own.	In place

5.3 HTTPS and browser protection

Control	What to do and why	Status
HTTPS everywhere	Install a free SSL certificate (AutoSSL) for the website and for the API sub-domain, and send every http:// visit to https://. The supplied .htaccess does the redirect.	Recommended
Modern TLS only	Allow TLS 1.2 and 1.3; disable old SSL/TLS versions and weak ciphers.	Recommended
Protection headers on the website	Upload the supplied .htaccess, put the real API address into it, and check the pages. It sets HSTS and the other headers described in section 4.11.	Recommended
Content-security policy	Run it in report-only mode for a week, then enforce it.	Recommended
API headers and HSTS	The API sends its own protection headers, including HSTS in production.	In place
Restricted site origins	Only the temple's own website addresses are allowed to talk to the API.	In place

5.4 Files, folders and secrets on the server

Control	What to do and why	Status
Nothing private in the public folder	Keep the API's application folder, settings, backups and uploaded files outside public_html. The supplied .htaccess also refuses files whose names start with a dot, source maps, logs, backups, SQL files and archives.	Recommended
Disable directory listing	Turn off "Indexes" so visitors cannot browse folder contents (also set in the supplied .htaccess).	Recommended
File permissions	Folders 755, ordinary files 644, any private settings file 600 (owner only).	Recommended
Remove old copies	Delete old zip files and old website builds that contain settings or keys, including copies in online storage.	Recommended
Disable unused services	Turn off FTP (use SFTP only), unused mail accounts and unused modules.	Recommended
Secrets kept out of code	Passwords and keys live in the cPanel application settings, never in the code or in a public folder.	In place

5.5 The Node.js application on cPanel

Control	What to do and why	Status
Node.js version	Use the newest version the cPanel Node.js selector offers (the software is tested on 24). Confirm compatibility with ZeroInfinity Infotech before go-live.	Recommended

Control	What to do and why	Status
Application folder and start-up file	Application root outside public_html; start-up file server.js; restart the application after every update.	Recommended
Settings in cPanel	Enter the settings listed in section 2.2 in the application's environment-variable screen, with NODE_ENV set to production.	Recommended
API on its own sub-domain	Give the API its own sub-domain and SSL certificate, and use that address as BACKEND_URL and in the website build.	Recommended
Number of servers in front	Set TRUST_PROXY to 1 on cPanel (2 with Cloudflare). A wrong number makes visitors share one address, or lets them fake theirs.	Recommended
Automatic restart	cPanel's application manager starts the application when needed and restarts it if it stops.	In place

5.6 The database and the other accounts

Control	What to do and why	Status
Database access list	In MongoDB Atlas, allow connections only from the hosting server's address (a dedicated IP address is best) and switch off "allow access from anywhere".	Recommended
Own database and user	Give the live site its own database name and a database user with a long password, different from any test copy.	Recommended
Provider alerts	Switch on Atlas alerts for unusual traffic and failed logins.	Recommended
Other keys	Use live payment keys, a new Cloudinary secret and a mail app password that were never kept in a shared file; list only the temple's domain in the Google sign-in settings.	Recommended

5.7 Malware, updates, e-mail and monitoring

Control	What to do and why	Status
Malware scanning	Enable ImunifyAV / Imunify360 or ClamAV with daily scans and automatic quarantine.	Recommended
Automatic updates	Keep cPanel/WHM and the operating system up to date, with automatic security updates switched on.	Recommended
Library scanning	Run npm audit on the API and on the website every month and update what it reports.	Recommended
Uptime monitoring	Use an uptime monitor on the API's health address; alert by e-mail or SMS if it fails.	Recommended
Log review	Review login failures, firewall blocks and the audit log every week.	Recommended

Control	What to do and why	Status
E-mail protection	Set SPF, DKIM and DMARC for the sending domain so nobody can send forged e-mail in the temple's name, and confirm that the server may send mail out (ports 465 or 587).	Recommended

6. Backup and recovery

A backup that sits on the same server as the system is not a real backup. This is what exists today and what is recommended.

Item	What it covers	Status
Backup and Restore in the portal	Administrators with the system area can create a backup of the site's content and records. Backup files are private and can be downloaded for 10 minutes only.	In place
Restore and delete	Only the super administrator can restore or delete a backup. A restore never overwrites user accounts.	In place
cPanel account backup	A nightly backup of the whole hosting account (JetBackup or cPanel Backup), with a copy sent to a different location.	Recommended
Database backup	A paid MongoDB Atlas plan includes automatic cloud backups; the free plan does not, so please check the plan in use.	Recommended
A record of the settings	Keep the list of settings and the deployment steps in a safe place, so that a new server can be built quickly.	Recommended
Three copies, two kinds of storage, one elsewhere	Keep at least three copies, on two kinds of storage, with one outside the hosting account. Encrypt backup files before they leave the system.	Recommended
Restore test	Once every quarter, restore a recent backup into a test copy and check that it opens.	Recommended

Measure	Target	Meaning
Maximum data loss	Up to 24 hours	With a nightly backup, at most one day of changes could be lost.
Time to restore	A few hours	Time to prepare a new account or database and restore the latest backup.

7. Go-live checklist

These steps make the live website as protected as this report describes. Most can be carried out by ZeroInfinity Infotech as part of deployment.

Step	What to do	Status
1. Deploy the prepared version	Build the website with the real API address and upload it to public_html together with the supplied .htaccess. Create the Node.js application, upload the API, install it, enter the settings and start it. Until this is done, the live website has only the protections of the version that is running on it.	Recommended
2. Strong, separate keys	A new login-signing key for the live server, different from any test computer. Change the database, cloud-storage, mail and payment passwords if they were ever kept in a file that was shared or zipped.	Recommended
3. Super administrator	Change the super administrator's password inside the portal to a long one, remove the first-time password from the settings, and protect that e-mail account with two-step sign-in, because password-reset mail goes there.	Recommended
4. Check administrator accounts	Run the supplied check that lists any administrator still using a guessable password, and change or remove those accounts.	Recommended
5. Database access	Own database name and user, and Atlas access limited to the server's address.	Recommended
6. HTTPS and headers	AutoSSL on both addresses, redirect to https, the .htaccess checked, and the content-security policy in report-only mode for a week before it is enforced.	Recommended
7. E-mail	Send one real test message from the portal, set SPF, DKIM and DMARC, and confirm the mail provider's daily limit (the software stays below it).	Recommended
8. Payments and uploads	Live payment keys and return addresses, one small donation with each gateway, and one photograph uploaded to Cloudinary.	Recommended
9. Server protection	Two-step sign-in, firewall, brute-force protection, web application firewall and malware scanning, as listed in section 5.	Recommended
10. Backups	Schedule the nightly backups, and do the first restore test.	Recommended
11. Two-step sign-in for administrators	This is the largest protection still to be added in the software. Until then, use a long unique password for every administrator.	Recommended
12. Routine	Agree who carries out the routine tasks in section 9 and who is called in an incident (section 8).	Recommended

8. If something goes wrong

Step	Action
1. Contain	Suspend the account concerned and use “sign out everywhere”. If needed, the super administrator can switch on the maintenance page, or the server can be taken offline at the firewall.
2. Preserve	Do not delete logs. Save the audit log, the server logs and a fresh backup for the investigation.
3. Assess	Check the audit log and the server logs to see what was viewed or changed, and by whom.
4. Recover	Fix the cause, change the login-signing key (this signs everyone out), the database password and any exposed keys, then restore from a clean backup if records were altered.
5. Notify	Inform the temple’s responsible person and anyone affected, as the temple’s policy and Nepal’s applicable law require.
6. Learn	Record what happened and update this report and the checklist.

9. Routine maintenance

How often	Task
Daily	Automatic backup and malware scan. Read the notifications for new bookings and donations.
Weekly	Review the audit log, failed sign-ins and firewall blocks. Approve or hide visitor reviews and read contact messages. Confirm the backups were copied off the server.
Monthly	Install updates, run the library checks and the automated tests, and remove accounts of people who have left.
Quarterly	Restore a backup into a test copy. Review each administrator’s access areas and the cPanel, firewall and permission settings against section 5. Check that the SSL certificates renewed.
Yearly	An independent penetration test by an outside specialist. Review how long visitor data is kept, change the main keys and passwords, and update this report.

10. Shared responsibilities

Zeroinfinity Infotech	Ram Mandir administration
Builds and maintains the security of the software described in section 4.	Keeps passwords and the e-mail accounts used for the portal safe, with two-step sign-in where possible.
Configures the server protection in section 5 and the go-live steps in section 7 at deployment, where it manages the hosting account.	Decides who is an administrator and what each may do, and removes access promptly when someone leaves.

ZeroInfinity Infotech	Ram Mandir administration
Provides updates and fixes when a security problem is found, and re-runs the automated tests after every change.	Keeps the hosting, database, cloud-storage, mail and payment-gateway accounts under the temple's own control.
Advises on backups, monitoring and incident handling, and investigates and corrects reported incidents.	Approves content, reviews and mailings; reports anything suspicious; decides how long visitor data is kept and handles privacy requests from devotees.

11. Scope and limits of this report

This report is based on a review of the project's source code, configuration templates and automated test records as at 6 October 2026, and on tests run against a throw-away copy of the system. It describes how the software is protected and how the server should be protected; it is not a certificate, and it is not the result of an outside penetration test. The cPanel and WHM settings in section 5 are the standard protections for hosting this software and are marked Recommended until they have been switched on and checked on the live server. The report covers the version of the temple software prepared and hardened by ZeroInfinity Infotech; an older copy of the website that is still running on a server does not have these protections until the prepared version is deployed.

Not yet tested with live accounts

- Real payments with the live eSewa, Khalti and ConnectIPS keys.
- Real uploads to the temple's own Cloudinary account.
- Real e-mail delivery through the temple's mail provider (a test message should be sent once after go-live; the mail provider limits the number of messages per day, and the host must allow outgoing mail).
- The production website build, with the supplied .htaccess, on the live cPanel host.

Known limits that were accepted or left for a later update

- Logins last 30 days because the temple asked for saved logins; the mitigation is that sessions can be ended at any time.
- The public site-settings address also contains the donation account details that the Donate page shows anyway.
- A few low-risk items, such as public view counters that can be changed without signing in, are recorded for a later update.
- Two-step sign-in for administrators is not yet part of the software (section 7, step 11).

12. Words used in this report

Word	Meaning
cPanel and WHM	The control panels of the hosting server. cPanel manages one hosting account; WHM manages the whole server.
AutoSSL	The automatic free security certificate that makes a website open over https.
Firewall	A filter that allows only the network traffic the server needs.

Word	Meaning
Web application firewall (ModSecurity)	A filter that recognises and blocks common attacks on web pages.
Two-step sign-in	Signing in with a password plus a second proof, such as a code from a phone app.
Rate limit	A cap on how many times something can be tried in a given time, to stop automatic guessing and flooding.
Double opt-in	A person is added to the newsletter only after they confirm from a message sent to their own inbox.
SPF, DKIM, DMARC	Records on the domain that prove an e-mail really comes from the temple and make forged e-mail easy to reject.
Audit log	A record of who did what and when in the administration portal.
Penetration test	A planned, authorised attack on the system by a security specialist, to find weaknesses before real attackers do.
Content-security policy	A rule sent to the browser that tells it which scripts and pictures a web page may load.

13. Verification and sign-off

This report was prepared by the ZeroInfinity Infotech administration from the project's source code, the security audit of 5 October 2026 and the automated test records, and is verified by the founder.

Role	Name	Signature	Date
Prepared by	ZeroInfinity Infotech — Administration		
Verified by	Sujan Subedi, Founder, ZeroInfinity Infotech		

Prepared by ZeroInfinity Infotech
zeroinfinitytechnologies.com